

ATP Ultra

Platform Audit

Executive Summary

Date: April 3, 2026
Prepared for: Mo Roowala,
Backend Fulfillment
Operations Lead
Platform: ATP Ultra —
Customer Success +
Student LMS
Stack: React 18 +
TypeScript + Vite +
Supabase
Scale: 1,400+ students,
growing to 2,000+
Audit Scope: Security,
Backend, UI/UX, Code
Quality, CSM Workflows

Total Findings: 78 Tickets

18 CRITICAL 26 HIGH 28 MEDIUM 6 LOW

32 fixed (41%) • 46 remaining • 7 critical items still open

CRITICAL: Why This Platform Cannot Go to Production

The following issues represent immediate, exploitable vulnerabilities that would put 1,400+ students' personal data, financial information, and account security at risk if this platform were deployed as-is.

& ANYONE CAN ACCESS ANY USER'S DATA

JWT tokens were parsed without signature verification. An attacker could forge a token with any user ID and access their data, grades, messages, and personal information. Two edge functions (get-dashboard-metrics, get-course-detail) were vulnerable. NOW FIXED.

& SECRETS COMMITTED TO VERSION CONTROL

The .env file was NOT in .gitignore. Supabase anon key, Facebook App ID, and project URL were exposed in git history. The JWT anon key doesn't expire until 2086. Even after rotation, the keys exist in git history forever unless scrubbed with BFG.

& ANY WEBSITE CAN CALL YOUR API

All 28 edge functions returned Access-Control-Allow-Origin: *. Any malicious website could make authenticated requests to create users, delete users, reset passwords, and modify data on behalf of logged-in users via CSRF attacks. NOW FIXED.

& PASSWORDS EMAILED IN PLAINTEXT

Password reset emails contained the new password as visible HTML text. Anyone intercepting the email (IT admin, email provider, man-in-the-middle) gets the password. This violates every security standard. NOW FIXED — now sends recovery links.

& XSS: ARBITRARY SCRIPT EXECUTION

The Vidalytics video player extracted <script> tags from external API responses and executed them directly in the browser via document.head.appendChild(). An attacker controlling the Vidalytics response could execute arbitrary JavaScript in every student's browser. NOW FIXED.

Still Open — Must Fix Before Launch

SEC-007: No rate limiting on any edge function

[OPEN]

Zero rate limiting on password reset, user creation, deletion, invitations. Enables brute force attacks, DoS, account enumeration, and spam.

SEC-008: File uploads have no server-side type verification

[OPEN]

Client-side extension check only. An attacker can upload malware.exe renamed as image.png. No magic byte validation, no Supabase storage bucket policies.

SEC-009: Impersonation links have no audit trail

[OPEN]

Admins can generate unlimited impersonation links. Target user is never notified. No persistent log. A compromised admin account = silent full access to every student.

SEC-011: No audit logging for admin actions**[OPEN]**

Delete user, reset password, create user — all admin actions log to console only. No database audit trail. Admin abuse or account compromise is completely undetectable.

SEC-012: No two-factor authentication**[OPEN]**

No MFA requirement for admin or CSM accounts. A single compromised password gives full access to 1,400+ student records.

Data Integrity & Scalability Risks

User Deletion Can Corrupt Your Database

The delete-user function manually looped through 18 tables deleting data BEFORE calling auth deletion. If auth deletion failed, the user's data was already gone with no rollback. NOW FIXED — auth deletion happens first, with try/catch cleanup.

The Platform Will Break at 2,000 Students

Multiple queries and systems were not designed for scale:

BE-002: Weekly reports take 11-33 HOURS for 2,000 users

[OPEN]

Sequential OpenAI API calls per user. 2 calls × 2,000 users = 4,000 API calls = 11-33 hours. Exceeds Deno edge function timeout. Needs background job queue.

BE-003: Community messages: N+1 queries, no pagination

[FIXED]

Every message view triggered 4 separate queries. Thread replies fetched sender profiles in a loop. No message limit. Fixed: batch fetch + 50-message pagination.

BE-004: No circuit breaker for external APIs

[OPEN]

If Lovable AI moderation is down, ALL messages fail to send. If OpenAI is down, ALL weekly reports fail. No retry, no fallback, no graceful degradation.

BE-005: User listing query not optimized

[OPEN]

get_users_with_progress RPC does heavy joins/aggregations. 2,000 users × 100+ fields = massive data transfer. 134 page loads to fetch all users.

BE-010: Realtime subscriptions won't scale

[OPEN]

2,000 students × 10 channels = 20,000 Supabase realtime connections. No connection pooling. No adaptive polling.

BE-006: Missing database indexes on high-query columns

[OPEN]

No indexes on: community_messages.is_deleted, user_onboarding.user_id, weekly_reports.user_id, leaderboard_cache.user_id.

CSM Workflow Failures

The CSM (Customer Success Manager) team manages 250 students each. The platform's CSM tools have multiple bugs and critical gaps that prevent effective student management. 6 bugs were reported by the team, alongside missing features that force manual workarounds.

Bugs Reported by CSM Team

CSM-BUG-1: Outreach counts are wrong

[FIXED]

Joseph: "I contacted 4 students but dashboard shows 12." Root cause: query counted ALL CSMs' contacts, not the logged-in CSM. Fixed: added per-CSM filter.

CSM-BUG-2: Active student shows as at-risk

[FIXED]

Sharon: Student accessed software but appears at-risk. Root cause: risk score only checked login date, not task activity. Fixed: uses MAX(login, task completion).

CSM-BUG-3: "Last seen" doesn't match reality

[FIXED]

Beenish: Dashboard timestamps don't match actual activity. Same root cause as bug #2. Fixed with combined activity date.

CSM-BUG-4: "View Full Profile" button broken

[FIXED]

Beenish: Button navigated to CSM panel but did nothing. Root cause: CSMPanel.tsx never read the navigation state. Fixed: now opens student detail view.

CSM-BUG-5: CSV field mapping broken in dashboard

[OPEN]

Nisha: CSV import field mapping doesn't work correctly. Needs investigation.

CSM-BUG-6: Bell notifications missing student activity

[OPEN]

Nisha: Notifications only show comments/messages/tickets. No alerts when students log in after absence, complete tasks, or pass quizzes.

Critical CSM Gaps

- Follow-up queue was capped at 240px (4-5 visible students). A CSM with 30+ at-risk students couldn't see them. [FIXED]
- Outreach status had only 2 options (Follow-up / Contacted). No way to track message sent, call scheduled, resolved. [FIXED — now 5 options]
- Student names were not clickable anywhere outside User Management. CSMs had to navigate multiple tabs. [FIXED]
- No student health score — only binary categories (at-risk / not at-risk). No composite scoring.
- No automated outreach triggers — CSMs must manually scan dashboard daily.
- No lifecycle stage engine or playbooks — new CSMs have no guidance on what to do at each stage.
- No Google Calendar integration — 1:1 coaching calls scheduled manually (Ihram).
- Student notes not sorted by date — most recent buried at bottom (Ihram).

Code Quality & Maintainability Risks

Quality Assessment

Mid-level feature output with junior-level security, architecture, and code hygiene. Not senior-level work.

Key Indicators

- TypeScript strict mode is OFF — noImplicitAny: false, strictNullChecks: false. 94 files contain ": any" type annotations. Makes refactoring dangerous and enables silent runtime bugs.
- 500+ occurrences of "any" or "as any" across source code and edge functions.
- 452 console.log/console.error calls left in production code.
- Zero React.memo usage across 400+ components — every list re-renders entirely on any state change. [FIXED — added to 6 key components]
- UserManagementOverview.tsx was 1,042 lines with 32 useState calls in a single component. [FIXED — split into hook + component]
- Dual toast libraries (Sonner + Radix) both mounted simultaneously. [FIXED — consolidated to Sonner]
- No route-based code splitting — entire app loaded as a single bundle. [FIXED — 17 routes lazy-loaded]
- ESLint @typescript-eslint/no-unused-vars was disabled. [FIXED — enabled with warnings]
- PWA manifest said "Elite E-Commerce" instead of "ATP Ultra". [FIXED]
- Premium font (Rebond Grotesque, 18 weight files) sitting in /public/fonts/ completely unused. [FIXED — activated]
- cmdk package installed but no command palette built. canvas-confetti and lottie-react installed but barely wired up.
- ModuleLesson.tsx (661 lines) duplicates video rendering logic from InlineLessonContent — maintenance nightmare.
- 333 migration files — excessive churn indicating iterative patching, not controlled schema evolution.
- Schema export references a DIFFERENT Supabase project than the live client config.

Platform Valuation

Cost to Build From Scratch (Competent US Team, \$120-\$180/hr)

Frontend (27 pages, 267 components)	900-1,350 hrs	\$108K - \$243K
Backend / DB (77 tables, broad domain)	550-850 hrs	\$66K - \$153K
Edge Functions (28 functions)	240-420 hrs	\$29K - \$76K
Design System	140-240 hrs	\$17K - \$43K
Testing / QA (none exists currently)	300-500 hrs	\$36K - \$90K
Deployment / Ops	80-140 hrs	\$10K - \$25K

TOTAL	2,210-3,500 hrs	\$265K - \$630K
--------------	------------------------	------------------------

Cost to Fix All Critical + High Issues

Secrets, auth, JWT, CORS, rate limiting	90-170 hrs	\$11K - \$31K
Roles, permissions, RLS, audit	70-140 hrs	\$8K - \$25K
Password reset, XSS, unsafe flows	40-90 hrs	\$5K - \$16K
DB integrity, indexes, migrations	60-120 hrs	\$7K - \$22K
Performance (N+1, reports, realtime)	60-120 hrs	\$7K - \$22K
Regression testing	40-80 hrs	\$5K - \$14K

TOTAL	360-720 hrs	\$43K - \$130K
--------------	--------------------	-----------------------

Bottom Line Valuation

\$25,000 — \$65,000 as-is

Salvage value. The range where fixing beats replacing, but only barely.

Remediation Completed

32 of 78 tickets (41%) have been fixed during this audit cycle. Here is the breakdown:

Security: 6 / 15 fixed (40%)

JWT verification, CORS lockdown, XSS removal, security headers, role restrictions, password reset

UI/UX: 17 / 24 fixed (71%)

Font, colors, dark mode, cards, dashboard, page transitions, empty states, skeleton loading, manifest

Code Quality: 8 / 11 fixed (73%)

Toast consolidation, React.memo, lazy loading, component splitting, ESLint, Vite chunks

Backend: 3 / 17 fixed (18%)

N+1 fix, message pagination, delete-user transaction order

Workflows: 2 / 11 fixed (18%)

Dead AI code removed, calendar join button UX

CSM Bugs: 4 / 6 fixed (67%)

Outreach counts, risk score, view profile, email editing

Major Redesigns Delivered

- CSM Panel: Command center with morning briefing, 4 KPI cards, full-height urgency queue, tabs 6!4, outreach status 2!5 options
- Brand Leads: Table view with inline status editing, sortable columns, pipeline summary bar, inline add row, filter pills
- My Plan: Vertical timeline with connected phase nodes, hero summary bar, expandable week cards
- Community: Textarea with Shift+Enter, message editing, N+1 fix, pagination with "Load older" button

Remaining Critical Work

These 7 items must be resolved before the platform can safely serve 2,000+ students:

1. Rate Limiting (SEC-007)

No protection against brute force, DoS, or spam on any of the 28 edge functions. A single attacker could lock out all users by spamming password resets.

2. Audit Logging (SEC-011)

Admin actions (delete user, reset password, impersonate) leave no persistent trail. If an admin account is compromised, there is zero forensic evidence.

3. Two-Factor Auth (SEC-012)

A single compromised password = full access to all student data. No MFA on admin or CSM accounts.

4. Weekly Report Scaling (BE-002)

At 2,000 users, report generation takes 11-33 hours. Needs a background job queue, not an edge function.

5. Circuit Breaker (BE-004)

When Lovable AI or OpenAI goes down, community messaging and weekly reports fail entirely. No graceful degradation.

6. User Listing Optimization (BE-005)

Admin/CSM user management query does heavy joins. Performance degrades linearly with user count.

7. TypeScript Strict Mode (CQ-002)

94 files with ": any" types. Refactoring is dangerous — type errors are silent. Must enable incrementally.

External Integrations (18 Services)

Supabase	Core infrastructure (DB, Auth, Realtime, Storage, Edge Functions)	CRITICAL
OpenAI GPT-4o-mini	Weekly report generation, psychology insights	HIGH
Lovable AI / Gemini 3 Flash	Community message moderation	HIGH
Google OAuth 2.0	Account linking for Calendar + Drive	MEDIUM
Google Calendar API	Training call sync, Google Meet links	MEDIUM
Google Drive API	Video file migration	LOW
YouTube IFrame API	Video embedding (free, public)	LOW
Vimeo oEmbed	Video embedding (free)	LOW
Vidalytics	Video hosting + analytics (paid, views count against account)	MEDIUM
Facebook App	Social auth (configured but unclear if active)	LOW
Web Push / VAPID	Browser push notifications	MEDIUM
Resend	Password reset emails	MEDIUM
Crisp Chat	Live chat widget (currently disabled)	LOW
Fathom AI	Meeting recordings, transcripts, summaries	MEDIUM
SME Central Hub	External ticket sync (API key was HARDCODED in source)	HIGH
Onboarding Webhook	Missed onboarding call updates	LOW
Google Fonts	Montserrat CDN	LOW
Deno / esm.sh	Edge function runtime	CRITICAL